

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5 TOTAL MARKS: 50

Annexure A

Industry Problem-Solving Task

Code of Conduct:

*I **T Sanhith(192311228)** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:

Annexure A
Industry Problem-Solving Task

1. A multinational enterprise is deploying IPsec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both
- B. Design packet flow with appropriate IPsec modes (transport/tunnel)
- C. Justify protocol selection for different data types
- D. Evaluate performance vs security trade-offs

Problem Analysis

A multinational enterprise communicates between branch offices through the public internet. Since the transmitted data may include confidential business information, financial records, employee information, and general network traffic, IPsec should provide both **confidentiality** and **integrity**.

A. Identification of Traffic Requiring AH, ESP, or Both

Type of Traffic	Recommended Protocol	Reason
General confidential business data	ESP	Provides encryption and integrity
Financial transactions	ESP with strong integrity protection	Requires confidentiality and authentication
Sensitive employee/customer data	ESP	Protects against unauthorized access

Non-confidential traffic requiring integrity	AH	Ensures authentication and integrity
Highly sensitive communication	ESP with authentication/integrity	Provides confidentiality and integrity together
Branch-to-branch VPN traffic	ESP Tunnel Mode	Protects the entire internal packet

Recommendation: In a real enterprise environment, ESP is generally preferred because it provides confidentiality along with integrity and authentication. AH can be used when only authentication and integrity are required.

B. IPSec Packet Flow and Modes

1. Transport Mode

Transport mode protects only the payload of the original IP packet.

Original Packet

[IP Header][TCP/UDP Header + Data]

After IPSec ESP Transport Mode

[IP Header][ESP Header][Encrypted TCP/UDP Header + Data][Authentication Data]

Suitable for:

- Host-to-host communication
- Secure communication between specific servers
- Internal systems where routing information must remain visible

2. Tunnel Mode

Tunnel mode encapsulates and protects the complete original IP packet.

Original Packet

[Original IP Header][TCP/UDP Data]

After IPSec ESP Tunnel Mode

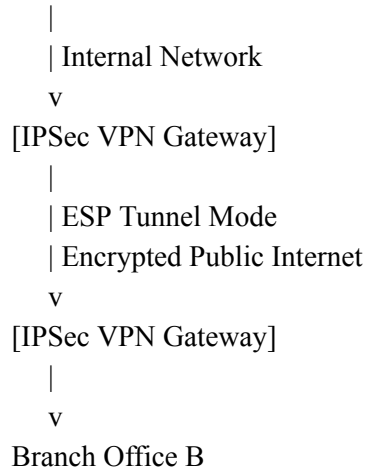
[New IP Header][ESP Header][Encrypted Original IP Packet][Authentication Data]

Suitable for:

- Branch office VPN connections
- Site-to-site communication
- Communication over the public internet

Recommended Enterprise Flow

Branch Office A



C. Justification for Protocol Selection

AH:

- Provides integrity.
- Provides authentication.
- Does not encrypt data.
- Suitable when confidentiality is not required.

ESP:

- Provides confidentiality through encryption.
- Can also provide integrity and authentication.
- Suitable for sensitive enterprise communication.

For branch-to-branch communication, ESP Tunnel Mode is the most suitable choice because it hides the internal network structure and encrypts the original packet.

D. Performance vs Security Trade-Offs

Factor	Higher Security	Higher Performance
Encryption	Strong encryption such as AES-256	Lower encryption overhead
Packet processing	More authentication checks	Faster processing
Tunnel mode	Higher protection	Additional packet overhead
Key length	Longer keys	More computational cost

Conclusion:

The enterprise should use ESP Tunnel Mode with strong encryption and integrity protection for sensitive branch-to-branch communication. For less sensitive traffic, optimized security policies can reduce unnecessary performance overhead.

2. An organization faces frequent key management issues in its IPSec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

A. Analyze current SA lifecycle issues

B. Design an automated key management mechanism (e.g., IKE-based) C.

Propose a strategy for key renewal and revocation

D. Evaluate scalability and fault tolerance

Problem Analysis

The organization experiences problems such as expired keys and mismatched keys. Manual key management is difficult and error-prone, especially in a large enterprise with many branch offices.

A. Analysis of SA Lifecycle Issues

A Security Association has the following lifecycle:

Creation

↓

Key Exchange

↓

Active Communication



Key Renewal



Expiration



Deletion

Common problems include:

1. Keys expire before renewal.
2. Different devices contain different keys.
3. Manual configuration causes human errors.
4. Old or compromised keys may remain active.
5. Large networks create a large number of Security Associations.

B. Automated Key Management Using IKE

The recommended solution is to use **Internet Key Exchange (IKE)** for automatic Security Association and key management.

Proposed Architecture

Branch A VPN Gateway



| IKE Authentication



Key Exchange



Generate Shared Session Keys



Create IPSec Security Association



Secure ESP Communication

Process

1. Two IPSec gateways initiate IKE communication.
2. Both parties authenticate each other.

3. Secure cryptographic parameters are negotiated.
4. Session keys are generated automatically.
5. IPSec Security Associations are created.
6. Communication begins using ESP.
7. Before key expiration, automatic rekeying occurs.

C. Key Renewal and Revocation Strategy

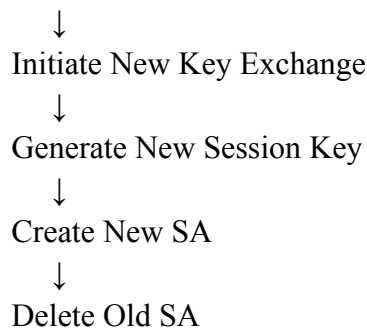
The organization should implement:

- **Automatic rekeying** before key expiration.
- **Time-based lifetime policies** for Security Associations.
- **Certificate revocation** for compromised devices.
- Immediate deletion of compromised Security Associations.
- Logging and monitoring of failed key exchanges.

Example:

SA Lifetime = 8 Hours

After 7 Hours:



D. Scalability and Fault Tolerance

For a large enterprise:

1. Use centralized security policies.
2. Deploy redundant VPN gateways.
3. Use load balancing for high traffic.
4. Maintain backup authentication servers.
5. Use automated monitoring for failed IKE negotiations.
6. Synchronize configuration across multiple gateways.

Evaluation

Aspect	Manual Management	Automated IKE Management
Scalability	Low	High
Human Error	High	Low
Key Renewal	Manual	Automatic
Fault Recovery	Slow	Faster
Enterprise Suitability	Limited	Excellent

3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios**
- B. Analyze key management and trust models**
- C. Recommend a solution with justification**
- D. Design a high-level implementation workflow**

Problem Analysis

A financial services company handles confidential information such as transaction details, customer information, and internal financial documents. Therefore, email communication must provide:

- Confidentiality
- Integrity
- Authentication
- Non-repudiation

A. Comparison Between PGP and S/MIME

Feature	PGP	S/MIME
---------	-----	--------

Encryption	Yes	Yes
Digital Signature	Yes	Yes
Trust Model	Web of Trust	Certificate Authority
Enterprise Integration	Moderate	High
Certificate Management	User-managed	Centrally managed
Email Client Support	Requires configuration	Common enterprise support
Scalability	Moderate	High
Best Use Case	Individual and flexible communication	Enterprise communication

B. Key Management and Trust Models

PGP

PGP uses a **Web of Trust**.

User A trusts User B

↓

User B verifies User C

↓

Trust relationships are established

The users are responsible for verifying and managing public keys.

S/MIME

S/MIME uses a **Certificate Authority (CA)**.

User

↓

Digital Certificate



Certificate Authority



Trusted Organization

The CA verifies identities and issues certificates.

C. Recommended Solution

For a financial services company, **S/MIME is recommended.**

Justification

1. Centralized certificate management.
2. Better integration with enterprise email systems.
3. Easier user administration.
4. Supports organizational trust policies.
5. Certificates can be revoked when compromised.
6. Suitable for large-scale corporate environments.

D. High-Level Implementation Workflow

Employee Sends Email



Create Email Content



Generate Digital Signature



Encrypt Using Recipient's Public Key



Send Secure Email



Recipient Receives Email



Validate Certificate

↓
Decrypt Using Private Key
↓
Verify Digital Signature
↓
Display Original Message

4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

- A. Identify limitations of existing filtering techniques**
- B. Analyze email headers for spoofing indicators**
- C. Design an improved detection model (rule-based or ML-based)**
- D. Evaluate effectiveness and false positive handling**

Problem Analysis

The company's basic filtering mechanisms are unable to stop modern phishing and spam attacks. Attackers can bypass simple keyword-based filters by using modified words, trusted-looking domains, and social engineering techniques.

A. Limitations of Existing Filtering Techniques

Traditional filtering may only check for simple spam keywords.

Example:

"Win a free prize!"

Attackers can bypass this by writing:

"W1n a Fr33 Pr!ze"

Limitations include:

1. Keyword-based systems are easy to bypass.
2. Legitimate emails may contain suspicious words.
3. Headers may not be properly analyzed.
4. New phishing techniques may not match existing rules.
5. Basic filters cannot easily detect social engineering attacks.

B. Email Header Analysis for Spoofing

The system should analyze:

1. From Address

Example:

From: bank-security@secure-login.com

The sender may appear legitimate but use a suspicious domain.

2. Reply-To Address

The **Reply-To** address may be different from the **From** address.

From: support@trustedbank.com

Reply-To: attacker@fake-domain.com

This can indicate phishing.

3. SPF

SPF checks whether the sending server is authorized to send emails for a domain.

4. DKIM

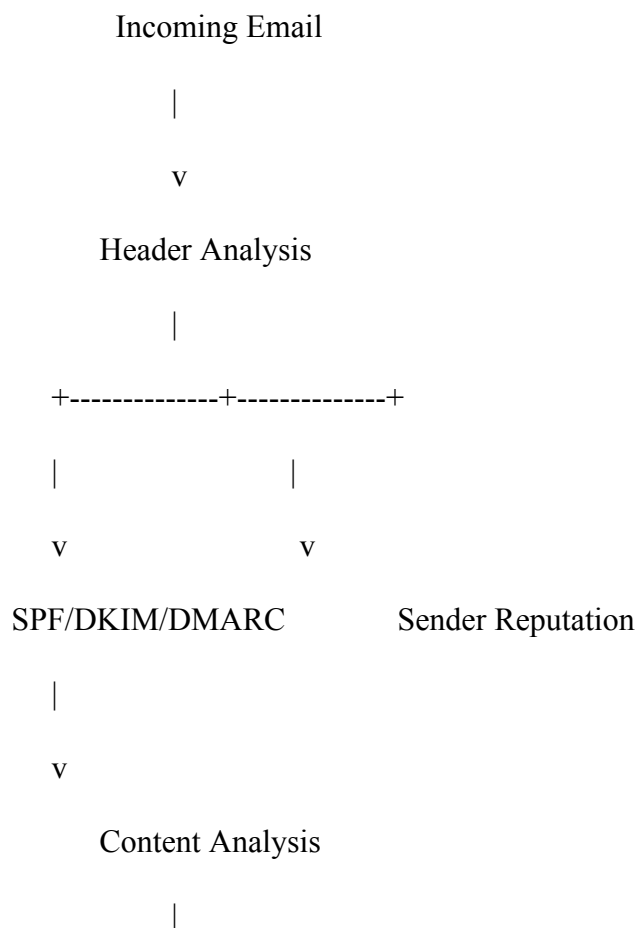
DKIM verifies that the email has not been modified and was authorized by the sending domain.

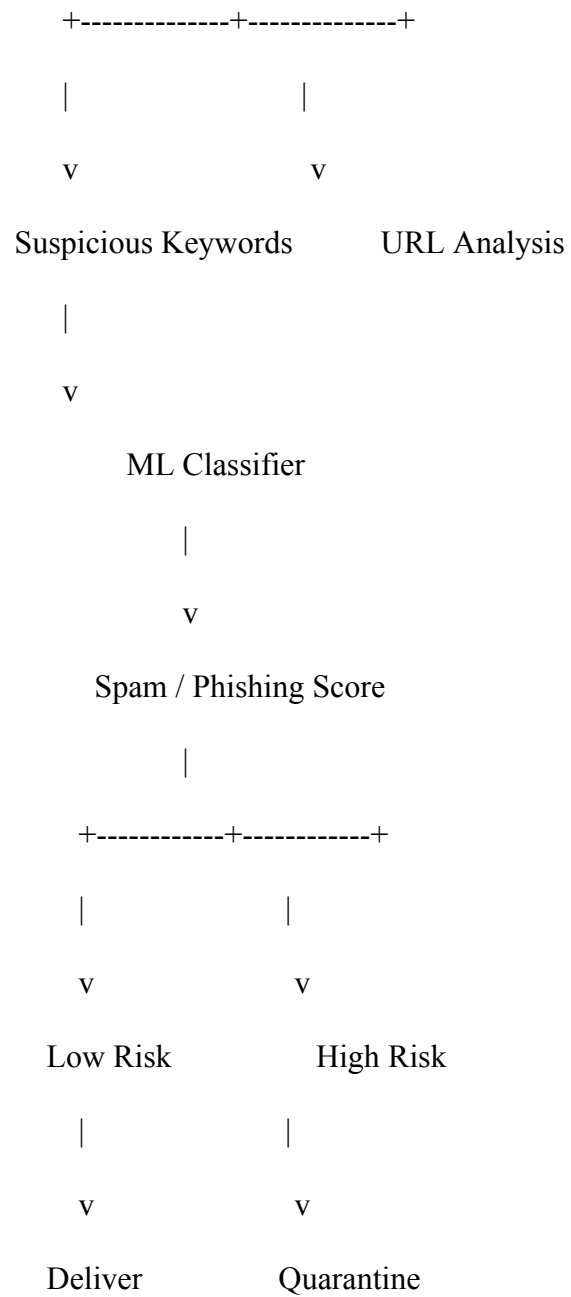
5. DMARC

DMARC combines SPF and DKIM policies to improve domain authentication.

C. Improved Detection Model

A hybrid approach can be used.





The detection system can use features such as:

- Sender domain reputation
- SPF validation
- DKIM validation
- DMARC policy

- Number of suspicious URLs
- Presence of shortened URLs
- Urgent language
- Excessive special characters
- Attachment type
- Previous sender reputation

A Machine Learning model such as **Random Forest**, **Naive Bayes**, or **Logistic Regression** can classify emails based on these features.

D. Effectiveness and False Positive Handling

A good system should avoid blocking legitimate emails.

Recommended actions:

R	Action
---	--------

i	
s	
k	
L	
e	
v	
e	
l	

L	Delive
o	r
w	normal
	ly

M Mark
e as
d suspici
i ous
u
m

H Move
i to
g quaran
h tine

V Block
e and
r alert
y securit
H y team
i
g
h

False positives can be reduced by:

1. Using a confidence score.
2. Maintaining approved sender lists.
3. Allowing users to report incorrectly classified emails.
4. Periodically retraining ML models.
5. Reviewing quarantined messages.

5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

A. Identify potential certificate-related vulnerabilities

B. Analyze trust chain and validation process

C. Propose secure certificate storage and management practices D.

Recommend improvements for user awareness and system configuration

Problem Analysis

The security audit found that encrypted emails are vulnerable because certificates are not being handled correctly. Even strong encryption becomes ineffective if attackers can compromise private keys or use untrusted certificates.

A. Potential Certificate-Related Vulnerabilities

The following problems may occur:

1. Expired certificates are still accepted.
2. Self-signed or untrusted certificates are accepted.
3. Private keys are stored insecurely.
4. Revoked certificates are not checked.
5. Users ignore certificate warnings.
6. Weak cryptographic algorithms are used.
7. Certificates are issued to incorrect identities.

8. Certificate expiration is not monitored.

B. Trust Chain and Validation Process

The certificate validation process should follow a trusted chain.

User Certificate



Intermediate Certificate Authority



Root Certificate Authority



Trusted Root Store

Before accepting a certificate, the system should verify:

1. Is the certificate issued by a trusted CA?
2. Is the certificate currently valid?
3. Has the certificate expired?
4. Has the certificate been revoked?
5. Does the certificate belong to the expected sender?
6. Is the digital signature valid?

C. Secure Certificate Storage and Management

The company should implement the following practices:

1. Protect Private Keys

Private keys should be stored using:

- Hardware Security Modules (HSM)

- Trusted Platform Modules
- Encrypted certificate stores
- Strong access control

2. Centralized Certificate Management

A centralized system should monitor:

- Certificate issuance
- Certificate expiration
- Certificate renewal
- Certificate revocation

3. Automatic Renewal

Certificates should be renewed before expiration.

Certificate Expiry Approaching



Automatic Alert



Certificate Renewal



Deploy New Certificate



Revoke Old Certificate

4. Revocation Checking

The organization should validate revoked certificates using appropriate certificate status checking mechanisms.

D. User Awareness and System Configuration

Users should be trained to:

1. Never ignore certificate warnings.
2. Verify unexpected certificate changes.
3. Avoid sharing private keys.
4. Report suspicious signed or encrypted emails.
5. Use strong passwords to protect certificate stores.

System administrators should:

- Enforce trusted certificate authorities.
- Disable weak cryptographic algorithms.
- Enable certificate expiration alerts.
- Implement automatic revocation checks.
- Apply regular security updates.
- Audit certificate usage regularly.